



סקר סיכוני אבטחת מידע

SYSTRU Technology

סיסטרו טכנולוגיה

באפריל 2026 14: תאריך

CISO, שאדי איוב: מגיש

סודי — לשימוש פנימי בלבד

תוכן עניינים

1. תקציר מנהלים

1.1 סיכום ממצאים לפי רמת סיכון

1.2 חמשת הסיכונים הקריטיים ביותר שזוהו

2. מבוא ומתודולוגיה

2.1 מטרות הסקר

2.2 היקף הסקר (Scope)

2.3 שיטת העבודה

3. רקע הארגון ונכסים

3.1 פרופיל החברה

3.2 סביבה רגולטורית

3.3 נכסי מידע עיקריים

4. ממצאי מיפוי בקרות ISO 27001

4.1 סיכום עמידה לפי סעיפי התקן

4.2 פירוט 30 סיכונים (כרטיסי סיכון)

5. הערכת סיכונים

5.1 טבלת מאסטר סיכונים - Top 10

6. תוכנית עבודה לטיפול בסיכונים

6.1 שלב א' - מיידי (Quick Wins - עד 90 יום)

6.2 שלב ב' - טווח בינוני (3-9 חודשים)

6.3 שלב ג' - טווח ארוך (9-18 חודשים)

7. סיכום והמלצות

7.1 המלצות מרכזיות להנהלה

7.2 ROI - החזר השקעה וערך עסקי

8. נספחים

1. תקציר מנהלים

מסמך זה מציג את תוצאות סקר הסיכונים המקיף שנערך בחברת סיסטרו טכנולוגיה (SYSTRU Technology), כחלק מתהליך ההיערכות ועמידה בדרישות תקן ISO/IEC 27001:2022. הסקר בחן 93 בקורות אבטחת מידע בהתאם לתקן, ומיפה את הפערים הקיימים בארגון.

חברת סיסטרו טכנולוגיה מספקת שירותי IT ותמיכה, הקמה וניהול רשתות תקשורת, התקנת מצלמות אבטחה (CCTV), מערכות מתח נמוך, ועובדת מול מוסדות ציבוריים (בתי ספר). בנוסף, החברה מנהלת אתר מכירות מקוון ומאגר סיסמאות מוצפן. עקב אופי הפעילות – גישה ישירה למערכות לקוחות, אחסון סיסמאות רגישות, ועבודה מול מוסדות ציבוריים – רמת החשיפה לסיכוני סייבר היא גבוהה במיוחד.

1.1 סיכום ממצאים לפי רמת סיכון

3

בינוני
10%

22

גבוה
73%

5

קריטי
17%

מתוך 93 בקורות שנבדקו: 79 בקורות אינן קיימות כלל, 10 קיימות, ו-4 קיימות באופן חלקי. שיעור העמידה הכולל עומד על כ-15% בלבד. מצב זה מחייב פעולה מיידית ומתוכננת לסגירת הפערים הקריטיים.

1.2 חמשת הסיכונים הקריטיים ביותר שזוהו

1. **העדר הפרדת סביבות:** רשתות לקוחות ורשת פנימית משותפת, סכנה לזליגת מידע בין סביבות.
2. **ניהול גישה והרשאות לקוי:** הרשאות Admin גורפות למערכות לקוחות ללא עקרון Least Privilege.
3. **העדר ניהול תיקוני אבטחה (Patch Management):** שרתים וציוד רשת ללא עדכוני אבטחה שוטפים.
4. **חולשות באבטחת אתר המכירות:** העדר WAF, בדיקות חדירות, והצפנת נתוני סליקה.
5. **העדר תוכנית התאוששות מאסון (DRP):** אין תוכנית מוגדרת להמשכיות עסקית במקרה של אירוע סייבר.

2. מבוא ומתודולוגיה

2.1 מטרות הסקר

- הערכת מצב אבטחת המידע הארגוני של חברת סיסטרו טכנולוגיה ביחס לתקן ISO/IEC 27001:2022.
- זיהוי פערים מהותיים בבקורות אבטחת המידע בדגש על הסיכונים הייחודיים לחברת שירותי IT המנהלת מערכות לקוחות.
- הערכת רמת הסיכון הכוללת של הארגון, תוך התחשבות באופי הפעילות (גישה למערכות לקוחות, ניהול מצלמות אבטחה, אתר מכירות).
- גיבוש תוכנית עבודה מעשית ותעדוף לסגירת הפערים.

2.2 היקף הסקר (Scope)

הסקר כיסה את כל 10 הסעיפים של תקן ISO/IEC 27001:2022 ואת 93 הבקורות הנדרשות בנספח A של התקן. הבדיקה התמקדה בכלל מערכות המידע, תשתיות הרשת, מערכות ה-CCTV, אתר המכירות, מאגר הסיסמאות, ותהליכי העבודה מול לקוחות ומוסדות ציבוריים.

2.3 שיטת העבודה

הסקר בוצע בחמישה שלבים מרכזיים:

- שלב 1 – איסוף מידע ראשוני:** עיון במסמכים קיימים, בדיקת תשתיות IT, מיפוי רשתות ומערכות.
- שלב 2 – ראיונות עם בעלי תפקידים:** ראיונות עם מנהלים, אנשי IT, טכנאי שטח ומשתמשי קצה.

3. **שלב 3 – בדיקות טכניות:** סריקת תשתיות, בדיקת קונפיגורציות רשת, בדיקת הרשאות, ובדיקת אבטחת אתר המכירות.

4. **שלב 4 – ניתוח ממצאים:** הערכת סיכונים לפי מטריצת הסתברות/השפעה (3x3).

5. **שלב 5 – גיבוש המלצות:** תעדוף ממצאים וגיבוש תוכנית עבודה מפורטת.

3. רקע הארגון ונכסים

3.1 פרופיל החברה

חברת סיסטרו טכנולוגיה (SYSTRU Technology) הנה חברה מובילה בתחום שירותי ה-IT והתקשורת, המספקת מגוון רחב של פתרונות טכנולוגיים מתקדמים. החברה מתמחה במתן שירותי IT ותמיכה, הקמה וניהול רשתות תקשורת, התקנת מצלמות אבטחה (CCTV), הטמעת מערכות מתח נמוך, וכן מתן שירותים למוסדות ציבוריים, בדגש על בתי ספר. בנוסף, סיסטרו טכנולוגיה מנהלת אתר מכירות מקוון ומאגר סיסמאות מוצפן, תוך מתן דגש על אבטחת מידע ופרטיות. אופי הפעילות של החברה, הכולל גישה למערכות לקוחות וטיפול במידע רגיש, מחייב רמת אבטחת מידע גבוהה במיוחד ועמידה בתקנים מחמירים.

3.2 סביבה רגולטורית

- חוק הגנת הפרטיות ותקנותיו:** חוקים אלו מחייבים את החברה להגן על מידע אישי של לקוחות ועובדים.
- תקן ISO/IEC 27001:2022:** תקן בינלאומי לניהול אבטחת מידע, המהווה מסגרת מקיפה להגנה על נכסי מידע.
- דרישות אבטחת מידע ספציפיות של לקוחות:** במיוחד מוסדות ציבוריים, הדורשים עמידה בסטנדרטים מחמירים.
- תקנות הגנת הפרטיות הכללית (GDPR):** במידה והחברה מטפלת במידע של אזרחי האיחוד האירופי.

3.3 נכסי מידע עיקריים

- **מידע לקוחות:** פרטי התקשרות, נתוני שירות, מידע פיננסי (במידת הצורך), נתוני גישה למערכות לקוחות.
- **מאגרי סיסמאות מוצפנים:** מאגרים המכילים סיסמאות גישה למערכות פנימיות וחיצוניות.
- **נתוני אתר מכירות:** פרטי הזמנות, נתוני מוצרים, מידע על תשלומים, נתוני משתמשים.
- **תשתיות IT ורשתות:** שרתים, תחנות קצה, ציוד תקשורת, מערכות גיבוי, שירותי ענן.
- **מערכות CCTV:** מערכות הקלטה, מצלמות, נתוני וידאו מלקוחות (בתי ספר, עסקים).
- **קניין רוחני:** קוד מקור, מסמכי אפיון, נהלי עבודה, ידע מקצועי ייחודי.

4. ממצאי מיפוי בקרות ISO 27001

4.1 סיכום עמידה לפי סעיפי התקן

מתוך בחינת 93 בקרות ISO/IEC 27001:2022, נמצא כי:

• 79 בקרות אינן קיימות כלל: אלו פערים מהותיים הדורשים טיפול מיידי.

• 10 בקרות קיימות: בקרות אלו מיושמות באופן מלא.

• 4 בקרות קיימות באופן חלקי: בקרות אלו דורשות השלמה ושיפור.

שיעור העמידה הכולל עומד על כ-15% בלבד, מה שמצביע על צורך בהשקעה מהותית בתשתיות אבטחת המידע הארגוניות ובגיבוש תוכנית עבודה מקיפה לסגירת הפערים.

4.2 פירוט 30 סיכונים (כרטיסי סיכון)

להלן פירוט מלא של 30 הסיכונים שזוהו, מסודרים לפי רמת הסיכון:

סיכון 1: העדר הפרדת סביבות (רשתות לקוחות מול רשת

קריטי

פנימית)

נכס: תשתיות ניהול רשתות, מערכות לקוחות

תיאור הסיכון: רשתות הלקוחות והרשת הפנימית של החברה אינן מופרדות כראוי. טכנאים ניגשים למערכות לקוחות מאותה רשת בה נמצאים נכסי החברה הפנימיים, מה שמאפשר תנועה רוחבית (Lateral Movement) במקרה של פריצה.

ממצא / חולשה: אין הפרדת VLAN בין סביבות. אין Firewall פנימי בין רשת החברה לרשתות הלקוחות. גישה מרחוק ללקוחות מתבצעת ללא VPN ייעודי.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: פריצה לרשת לקוח דרך הרשת הפנימית עלולה לגרום לנזק תדמיתי חמור, תביעות משפטיות, ואובדן לקוחות. פגיעה אפשרית בעבודה מול מוסדות ציבוריים.

המלצה לטיפול: הקמת VLANs נפרדים לכל סביבה (פנימי, לקוחות, CCTV, אתר מכירות). התקנת Firewall פנימי עם חוקים מחמירים. הטמעת VPN ייעודי לגישה מרחוק ללקוחות.

תוכנית עבודה: שלב א' – מיידי (Quick Wins)

הפניה לרגולציה: ISO 27001: A.13.1.3 – הפרדת רשתות.

נכס: חשבונות משתמשים, מערכות לקוחות

תיאור הסיכון: טכנאי החברה משתמשים בחשבונות Admin משותפים לגישה למערכות לקוחות. אין מדיניות Least Privilege, ואין הפרדה בין הרשאות ניהול להרשאות תפעול.

ממצא / חולשה: חשבונות Admin משותפים ללא מעקב אישי. אין PAM (Privileged Access Management). סיסמאות Admin אינן מוחלפות בתדירות קבועה.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: שימוש לרעה בהרשאות Admin עלול לגרום לנזק בלתי הפיך למערכות לקוחות. אי-יכולת לזהות מי ביצע פעולה מסוימת.

המלצה לטיפול: הטמעת עקרון Least Privilege. יצירת חשבונות אישיים לכל טכנאי. הטמעת PAM לניהול גישה מיוחדת. החלפת סיסמאות תקופתית.

תוכנית עבודה: שלב א' – מיידי (Quick Wins)

נכס: שרתים, תחנות קצה, ציוד רשת

תיאור הסיכון: אין תהליך מסודר לעדכון תיקוני אבטחה בשרתים, תחנות קצה וציוד רשת. מערכות הפעלה ותוכנות אינן מעודכנות, מה שחושף את הארגון לפגיעויות ידועות.

ממצא / חולשה: שרתים עם עדכוני אבטחה חסרים של מספר חודשים. אין כלי WSUS או מערכת ניהול עדכונים. ציוד רשת (מתגים, נתבים) עם Firmware ישן.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: ניצול פגיעות ידועה עלול להוביל לפריצה מלאה לרשת, גניבת מידע, והשבתת שירותים ללקוחות.

המלצה לטיפול: הטמעת תהליך Patch Management שוטף. התקנת WSUS או כלי ניהול עדכונים מרכזי. עדכון Firmware בכל ציוד הרשת. הגדרת לוח זמנים קבוע לעדכונים.

תוכנית עבודה: שלב א' – מיידי (Quick Wins)

הפניה לרגולציה: ISO 27001: A.12.6.1 – ניהול פגיעויות טכניות.

נכס: אתר המכירות (E-Commerce), נתוני לקוחות

תיאור הסיכון: אתר המכירות חשוף לפגיעויות אינטרנטיות (OWASP Top 10). אין WAF (Web Application Firewall), לא בוצעו בדיקות חדירות, ונתוני סליקה אינם מוגנים כראוי.

ממצא / חולשה: אין WAF מותקן. מעולם לא בוצע Penetration Test. תעודת SSL קיימת אך אין הקשחה של פרוטוקולים (TLS 1.0/1.1 פעילים). אין הגנה מפני SQL Injection ו-XSS-1.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: דליפת נתוני כרטיסי אשראי תגרום לקנסות PCI-DSS, תביעות, ופגיעה קשה במוניטין. השבתת האתר תגרום לאובדן הכנסות.

המלצה לטיפול: התקנת WAF. ביצוע Penetration Test. הקשחת TLS (ביטול גרסאות ישנות). הטמעת הגנות OWASP. עמידה בדרישות PCI-DSS.

תוכנית עבודה: שלב א' – מידי (Quick Wins)

הפניה לרגולציה: ISO 27001: A.14.1.2 – אבטחת שירותי יישומים ברשתות ציבוריות.

סיכון 5: העדר תוכנית המשכיות עסקית והתאוששות מאסון

קריטי

(BCP/DRP)

נכס: כלל שירותי החברה, אתר המכירות

תיאור הסיכון: אין תוכנית מוגדרת להמשכיות עסקית (BCP) או התאוששות מאסון (DRP). במקרה של אירוע סייבר, כשל חומרה, או אסון טבע – אין תהליך מוגדר לשחזור השירותים.

ממצא / חולשה: אין מסמך BCP/DRP כתוב. לא הוגדרו RTO ו-RPO לשירותים קריטיים. אין אתר DR חלופי. לא בוצעו תרגולי שחזור.

ניתוח CIA: סודיות: בינונית | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: השבתה ממושכת של שירותים תגרום לאובדן לקוחות, פגיעה בהכנסות מאתר המכירות, ואי-עמידה בהתחייבויות מול מוסדות ציבוריים.

המלצה לטיפול: גיבוש תוכנית BCP/DRP מלאה. הגדרת RTO/RPO לכל שירות קריטי. הקמת אתר DR או פתרון ענן. ביצוע תרגולי שחזור תקופתיים.

תוכנית עבודה: שלב א' – מיידית (Quick Wins)

הפניה לרגולציה: ISO 27001: A.17.1 – המשכיות אבטחת מידע.

נכס: כלל נכסי הארגון

תיאור הסיכון: לא קיימת מדיניות אבטחת מידע כתובה ומאושרת על ידי ההנהלה. אין מסמך מדיניות המגדיר את עקרונות האבטחה, אחריות, וכללי התנהגות.

ממצא / חולשה: אין מסמך מדיניות אבטחת מידע. אין הגדרת תפקידים ואחריות בתחום האבטחה. אין תהליך סריקה ועדכון מדיניות.

ניתוח CIA: סודיות: בינונית | שלמות: בינונית | זמינות: בינונית

השפעה עסקית: העדר מדיניות מונע הסמכה ל-ISO 27001 ומקשה על עמידה בדרישות רגולטוריות. פוגע ביכולת להשתתף במכרזים ציבוריים.

המלצה לטיפול: כתיבת מדיניות אבטחת מידע מקיפה. אישור המדיניות על ידי ההנהלה. הפצה לכלל העובדים. סריקה שנתית.

תוכנית עבודה: טווח קצר (עד 3 חודשים)

נכס: תהליכים ארגוניים

תיאור הסיכון: אין הפרדת תפקידים ברורה בין פונקציות IT שונות. אותו טכנאי מבצע התקנה, תחזוקה, וגם ניהול הרשאות – ללא בקרה צולבת.

ממצא / חולשה: טכנאים בעלי הרשאות מלאות לכל המערכות. אין הפרדה בין מי שמתקין לבין מי שמאשר. אין בקרה על פעולות קריטיות.

ניתוח CIA: סודיות: בינונית | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: סיכון להונאה פנימית, שגיאות לא מבוקרות, ואי-עמידה בדרישות ביקורת.

המלצה לטיפול: הגדרת מטריצת הפרדת תפקידים. הגבלת הרשאות לפי תפקיד. הטמעת תהליך אישור כפול לפעולות קריטיות.

תוכנית עבודה: קצר (Quick Wins)

הפניה לרגולציה: ISO 27001: A.6.1.2 – הפרדת תפקידים.

נכס: אתר המכירות, תהליכי פיתוח

תיאור הסיכון: אתר המכירות מפותח ומתוחזק ללא שילוב עקרונות אבטחה בתהליך הפיתוח (Security by Design). אין Code Review, ואין בדיקות אבטחה לפני העלאה לייצור.

ממצא / חולשה: אין תהליך SDLC מאובטח. אין Code Review. אין סריקות קוד אוטומטיות (SAST/DAST). שינויים מועלים ישירות לייצור.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: פיתוח לא מאובטח של אתר המכירות עלול להוביל לפגיעות קריטיות, דליפת מידע לקוחות, ופגיעה במוניטין.

המלצה לטיפול: הטמעת מתודולוגיית Secure SDLC. ביצוע Code Review. הטמעת סריקות אבטחה אוטומטיות (SAST/DAST).

תוכנית עבודה: טווח בינוני (3-6 חודשים)

הפניה לרגולציה: ISO 27001: A.14.2.5 – עקרונות פיתוח מאובטח.

נכס: עובדים מרוחקים, ציוד קצה

תיאור הסיכון: אין מדיניות ברורה לעבודה מרחוק, מה שחושף את הארגון לסיכונים הנובעים משימוש ברשתות לא מאובטחות וציוד אישי, וכן לחוסר פיקוח על מידע ארגוני מחוץ למשרד.

ממצא / חולשה: עובדים מתחברים מרחוק ללא הנחיות ברורות לגבי אבטחת הרשת הביתית, שימוש ב-VPN, או הגנה על ציוד קצה. אין מדיניות לגבי אחסון מידע מקומי.

ניתוח CIA: סודיות: גבוהה | שלמות: בינונית | זמינות: בינונית

השפעה עסקית: חשיפה לסיכוני אבטחה הנובעים מעבודה מרחוק, פגיעה במוניטין, ואי-עמידה בדרישות רגולטוריות.

המלצה לטיפול: גיבוש מדיניות עבודה מרחוק מקיפה, הכוללת דרישות אבטחה לחיבור מרחוק, שימוש ב-VPN, הגנה על ציוד קצה, והנחיות לאחסון מידע.

תוכנית עבודה: טווח קצר (עד 3 חודשים)

נכס: עובדים חדשים

תיאור הסיכון: אין תהליך מסודר לבדיקת רקע של עובדים וטכנאים חדשים לפני מתן גישה למערכות לקוחות רגישות.

ממצא / חולשה: אין בדיקת רקע פלילי. אין חתימה על הסכם סודיות (NDA) לפני קבלת גישה. אין תהליך Onboarding מוגדר מבחינת אבטחה.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: עובד לא מתאים עם גישה למערכות לקוחות עלול לגרום לנזק מכוון או בלתי מכוון.

המלצה לטיפול: הגדרת תהליך בדיקת רקע חובה. חתימה על NDA לפני קבלת גישה. תהליך Onboarding מובנה הכולל הדרכת אבטחה.

תוכנית עבודה: קצר (Quick Wins)

נכס: כלל העובדים

תיאור הסיכון: אין תוכנית מודעות מסודרת לאבטחת מידע. עובדים וטכנאים אינם מודעים לסיכוני פשינג, הנדסה חברתית, ונהלי אבטחה בסיסיים.

ממצא / חולשה: לא בוצעו הדרכות אבטחה. אין סימולציות פשינג. אין חומרי הדרכה זמינים. עובדים אינם מודעים לנהלי דיווח על אירועים.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: טעויות אנוש כתוצאה מחוסר מודעות עלולות להוביל לפריצות אבטחה, דליפת מידע, ופגיעה במוניטין.

המלצה לטיפול: גיבוש תוכנית מודעות והדרכה שנתית. ביצוע הדרכות חובה לכל העובדים. סימולציות פשינג תקופתיות.

תוכנית עבודה: טווח קצר (עד 3 חודשים)

הפניה לרגולציה: ISO 27001: A.7.2.2 – מודעות, חינוך והדרכה.

נכס: כלל המידע הארגוני

תיאור הסיכון: אין מדיניות סיווג מידע ברורה, ואין תהליך מוגדר לסיווג נכסי מידע לפי רגישותם. מידע רגיש מאוחסן לעיתים יחד עם מידע פחות רגיש.

ממצא / חולשה: אין מדיניות סיווג מידע כתובה. אין תיוג של קבצים ומסמכים. עובדים אינם מודעים לרגישות המידע שהם מטפלים בו.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: דליפת מידע רגיש עלולה לגרום לנזק תדמיתי, קנסות רגולטוריים, ופגיעה במוניטין.

המלצה לטיפול: גיבוש מדיניות סיווג מידע. הטמעת תהליך סיווג מידע. הדרכת עובדים בנושא סיווג מידע.

תוכנית עבודה: טווח בינוני (3-6 חודשים)

נכס: מערכות CCTV, אמצעי אבטחה

תיאור הסיכון: גישה מרחוק למערכות CCTV של לקוחות מתבצעת ללא בקרה מספקת. סיסמאות ברירת מחדל לא שונו, ואין מעקב אחר גישות.

ממצא / חולשה: מצלמות עם סיסמאות ברירת מחדל. גישה מרחוק ללא MFA. אין לוגים של גישה למערכות CCTV. פורטים פתוחים לאינטרנט ללא הגנה.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: פריצה למצלמות אבטחה של לקוחות (כולל בתי ספר) תגרום לפגיעה חמורה בפרטיות ולחשיפה משפטית.

המלצה לטיפול: שינוי כל סיסמאות ברירת המחדל. הטמעת MFA לגישה מרחוק. סגירת פורטים מיותרים. הטמעת VPN לגישה למצלמות. ניטור גישות.

תוכנית עבודה: קצר

הפניה לרגולציה: ISO 27001: A.9.4.1 – הגבלת גישה למידע.

נכס: הרשאות גישה, חשבונות משתמשים

תיאור הסיכון: אין תהליך סקירת הרשאות תקופתי. חשבונות של עובדים שעזבו או לקוחות שהסתיימה ההתקשרות איתם נשארים פעילים.

ממצא / חולשה: חשבונות יתומים פעילים. אין סקירת הרשאות רבעונית. אין תהליך Offboarding מוגדר לביטול גישות.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: גישה בלתי מורשית למערכות על ידי עובדים לשעבר או גורמים עוינים. פגיעה במוניטין.

המלצה לטיפול: הטמעת תהליך סקירת הרשאות רבעוני. הגדרת תהליך Offboarding מקיף. שימוש בכלי IAM לניהול הרשאות.

תוכנית עבודה: שלב א' – מיידית (Quick Wins)

הפניה לרגולציה: ISO 27001: A.9.2.5 – סקירת זכויות גישה.

נכס: מפתחות הצפנה, תעודות דיגיטליות

תיאור הסיכון: אין תהליך מסודר לניהול מחזור החיים של מפתחות הצפנה ותעודות דיגיטליות, כולל יצירה, אחסון, שימוש, גיבוי וביטול, מה שחושף את המידע המוצפן לסיכון.

ממצא / חולשה: מפתחות הצפנה מאוחסנים באופן לא מאובטח. אין תהליך להחלפת מפתחות תקופתית. אין רישום מרכזי של כל המפתחות והתעודות.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: חשיפת מפתחות הצפנה עלולה להוביל לדליפת מידע מוצפן, פגיעה באמינות המערכות, וקנסות רגולטוריים.

המלצה לטיפול: הטמעת מערכת לניהול מפתחות (KMS). הגדרת תהליכים לניהול מחזור החיים של מפתחות הצפנה.

תוכנית עבודה: טווח בינוני (3-9 חודשים)

נכס: משרדים, חדרי שרתים

תיאור הסיכון: בקרת הגישה הפיזית למשרדי החברה ולחדר השרתים אינה מספקת. אין מערכת בקרת כניסה אלקטרונית ואין מצלמות פנימיות.

ממצא / חולשה: חדר שרתים ללא נעילה ייעודית. אין בקרת כניסה אלקטרונית. אין רישום כניסות ויציאות. אין מצלמות אבטחה פנימיות.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: גישה פיזית לא מורשית לשרתים עלולה לאפשר גניבת מידע או השבתת מערכות.

המלצה לטיפול: התקנת מערכת בקרת כניסה לחדר השרתים. התקנת מצלמות אבטחה פנימיות. ניהול יומן כניסות ויציאות.

תוכנית עבודה: טווח קצר (עד 3 חודשים)

הפניה לרגולציה: ISO 27001: A.11.1.1 – בקרת גישה פיזית.

נכס: תהליכי IT, נהלי עבודה

תיאור הסיכון: אין נהלי תפעול מתועדים ומסודרים למערכות IT, מה שמוביל לחוסר עקביות בביצוע פעולות, טעויות אנוש, וקושי בהעברת ידע.

ממצא / חולשה: פעולות תפעוליות מבוצעות באופן אד-הוק ללא תיעוד. עובדים חדשים מתקשים להשתלב בתפקיד ללא נהלים כתובים.

ניתוח CIA: סודיות: בינונית | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: חוסר עקביות בתפעול עלול להוביל לתקלות, פגיעה בשירות, וקושי בעמידה בדרישות רגולטוריות.

המלצה לטיפול: תיעוד נהלי תפעול קריטיים. הטמעת מערכת לניהול נהלים. הדרכת עובדים על הנהלים.

תוכנית עבודה: בינוני

הפניה לרגולציה: ISO 27001: A.12.1.1 – נהלי תפעול מתועדים.

נכס: תשתיות IT, מערכות לקוחות

תיאור הסיכון: שינויים בתשתיות IT ובמערכות לקוחות מבוצעים ללא תהליך ניהול שינויים מסודר (Change Management).

ממצא / חולשה: אין תהליך Change Management. שינויים מבוצעים ללא אישור מוקדם. אין תיעוד שינויים. אין תהליך Rollback מוגדר.

ניתוח CIA: סודיות: נמוכה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: שינוי לא מבוקר עלול להשבית מערכות לקוחות ולגרום לנזק כספי ותדמיתי.

המלצה לטיפול: הגדרת תהליך Change Management. אישור מוקדם לכל שינוי. תיעוד שינויים. הגדרת תהליך Rollback.

תוכנית עבודה: בינוני

נכס: שרתים, מערכות, ציוד רשת

תיאור הסיכון: אין איסוף מרכזי של לוגים ממערכות החברה. אירועי אבטחה אינם נרשמים ואינם מנוטרים, מה שמונע זיהוי פריצות ותקריות.

ממצא / חולשה: אין שרת Syslog מרכזי. לוגים מקומיים אינם נשמרים לתקופה מספקת. אין ניתוח לוגים. אין התראות על אירועים חריגים.

ניתוח CIA: סודיות: נמוכה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: אי-יכולת לזהות ולחקור אירועי אבטחה עלולה להוביל לנזק משמעותי, דליפת מידע, ופגיעה במוניטין.

המלצה לטיפול: הטמעת מערכת SIEM לאיסוף וניתוח לוגים מרכזי. הגדרת מדיניות שמירת לוגים. ניטור והתראות על אירועים חריגים.

תוכנית עבודה: בינוני

נכס: רשתות, מערכות, יישומים

תיאור הסיכון: אין ניטור אבטחה אקטיבי של הרשתות, המערכות והיישומים, מה שמונע זיהוי בזמן אמת של פעילות חשודה, תקיפות, ואירועי אבטחה.

ממצא / חולשה: אין מערכת SIEM או SOC פעילה. אין התראות על אירועי אבטחה. אין צוות המנטר אירועים באופן שוטף.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: אי-יכולת לזהות פריצות בזמן אמת. קושי בחקירת אירועים לאחר מעשה.

המלצה לטיפול: הטמעת מערכת SIEM, להגדיר כללי התראה, ולבנות יכולת ניטור אבטחה פנימית או חיצונית (SOC).

תוכנית עבודה: טווח ארוך (9-18 חודשים)

הפניה לרגולציה: ISO 27001: A.12.4.2 – ניטור אבטחה.

נכס: מידע רגיש, ערוצי תקשורת

תיאור הסיכון: אין בקורות מספקות על העברת מידע רגיש בתוך הארגון ומחוצה לו, מה שחושף את המידע לדליפה, שינוי או גישה בלתי מורשית.

ממצא / חולשה: מידע רגיש מועבר באמצעות ערוצים לא מאובטחים (לדוגמה, דוא"ל לא מוצפן). אין מדיניות לגבי העברת מידע לגורמי צד שלישי.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: דליפת מידע רגיש עלולה לגרום לנזק תדמיתי, קנסות רגולטוריים, ואובדן אמון לקוחות.

המלצה לטיפול: הגדרת מדיניות להעברת מידע. הטמעת פתרונות הצפנה לערוצי תקשורת. הדרכת עובדים בנושא העברת מידע מאובטחת.

תוכנית עבודה: טווח קצר

נכס: ספקים, שירותים חיצוניים, מוצרים

תיאור הסיכון: אין דרישות אבטחת מידע מוגדרות בתהליכי הרכש של מוצרים ושירותים, מה שמוביל להתקשרות עם ספקים שאינם עומדים בסטנדרטים הנדרשים וחושף את הארגון לסיכונים.

ממצא / חולשה: חוזים עם ספקים אינם כוללים סעיפי אבטחת מידע. אין תהליך הערכת סיכוני אבטחה לספקים חדשים.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: התקשרות עם ספקים לא מאובטחים עלולה להוביל לחשיפת מידע, פגיעה במוניטין, וקנסות רגולטוריים.

המלצה לטיפול: הגדרת דרישות אבטחת מידע בתהליכי רכש. הכללת סעיפי אבטחה בחוזים עם ספקים. ביצוע הערכת סיכוני אבטחה לספקים.

תוכנית עבודה: בינוני

הפניה לרגולציה: ISO 27001: A.15.1.2 – אבטחת שירותי ספקים.

נכס: ספקים ושותפים

תיאור הסיכון: אין ניהול סיכוני אבטחת מידע מול ספקים ושותפים עסקיים. ספקי ציוד ותוכנה אינם נדרשים לעמוד בדרישות אבטחה.

ממצא / חולשה: אין הסכמי אבטחה עם ספקים. אין הערכת סיכוני ספקים. אין מעקב אחר עמידת ספקים בדרישות אבטחה. אין סעיפי אבטחה בחוזים.

ניתוח CIA: סודיות: בינונית | שלמות: בינונית | זמינות: גבוהה

השפעה עסקית: פריצה דרך ספק עלולה לחשוף את מערכות החברה והלקוחות (Supply Chain Attack).

המלצה לטיפול: הגדרת תהליך לניהול אבטחת מידע בשרשרת האספקה. הכללת סעיפי אבטחה בחוזים עם ספקים. ביצוע הערכת סיכונים לספקים.

תוכנית עבודה: טווח ארוך

נכס: כלל נכסי הארגון

תיאור הסיכון: אין תוכנית ניהול אירועי אבטחה (Incident Response Plan) מוגדרת. במקרה של אירוע סייבר, אין תהליך מסודר לזיהוי, הכלה, חקירה ושחזור.

ממצא / חולשה: אין תוכנית IR. אין צוות תגובה לאירועים. אין נהלים לטיפול באירועים. אין תרגילים תקופתיים.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: אי-יכולת לטפל באירועי אבטחה ביעילות עלולה להוביל לנזק משמעותי, דליפת מידע, ופגיעה במוניטין.

המלצה לטיפול: פיתוח תוכנית IR מקיפה. הקמת צוות תגובה לאירועים. הגדרת נהלים לטיפול באירועים. ביצוע תרגילים תקופתיים.

תוכנית עבודה: בינוני

הפניה לרגולציה: ISO 27001: A.16.1.5 – ניהול אירועי אבטחה.

סיכון 25: תוכנית המשכיות עסקית והתאוששות מאסון

גבוהה

(BCP/DRP)

נכס: מערכות קריטיות, נתונים, פעילות עסקית

תיאור הסיכון: אין תוכנית המשכיות עסקית (BCP) ותוכנית התאוששות מאסון (DRP) מתועדות ונבדקות, מה שחושף את הארגון להפרעה ממושכת בפעילותו במקרה של אסון או כשל מערכתי.

ממצא / חולשה: אין BCP/DRP כתובים. אין בדיקות תקופתיות של תוכניות אלו. אין זיהוי של תהליכים עסקיים קריטיים וזמני התאוששות נדרשים (RTO/RPO).

ניתוח CIA: סודיות: בינונית | שלמות: בינונית | זמינות: גבוהה

השפעה עסקית: אובדן נתונים, השבתת שירותים, פגיעה במוניטין, וקנסות רגולטוריים.

המלצה לטיפול: גיבוש תוכנית BCP/DRP מקיפה. זיהוי תהליכים קריטיים. הגדרת RTO/RPO. ביצוע בדיקות ותרגילים תקופתיים.

תוכנית עבודה: טווח ארוך

הפניה לרגולציה: ISO 27001: A.17.1.1 – המשכיות עסקית.

נכס: מאגרי מידע

תיאור הסיכון: מאגרי המידע של החברה (מאגר סיסמאות, נתוני לקוחות, נתוני CCTV) אינם מוגדרים ומזוהים באופן רשמי בהתאם לחוק הגנת הפרטיות.

ממצא / חולשה: מאגרי מידע לא רשומים אצל רשם מאגרי המידע. אין מיפוי מלא של מאגרי המידע. אין הגדרת מטרות ובעלים לכל מאגר.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: אי-רישום מאגרי מידע מהווה הפרה של חוק הגנת הפרטיות וחושף את החברה לקנסות ותביעות.

המלצה לטיפול: מיפוי כל מאגרי המידע. רישום אצל רשם מאגרי המידע. הגדרת בעלים ומטרות לכל מאגר. עמידה בתקנות הגנת הפרטיות.

תוכנית עבודה: בינוני

הפניה לרגולציה: ISO 27001: A.8.1.1 – מלאי נכסים / חוק הגנת הפרטיות.

נכס: מידע קריטי, מאגר סיסמאות, אתר מכירות

תיאור הסיכון: תהליך הגיבוי אינו מסודר ואינו מכסה את כל הנכסים הקריטיים. לא בוצעו בדיקות שחזור לאימות תקינות הגיבויים.

ממצא / חולשה: גיבוי חלקי בלבד. אין גיבוי Off-site. לא בוצעו בדיקות שחזור. אין מדיניות גיבוי כתובה. מאגר הסיסמאות מגובה באופן לא סדיר.

ניתוח CIA: סודיות: נמוכה | שלמות: גבוהה | זמינות: גבוהה

השפעה עסקית: אובדן נתונים קריטיים עלול להשבית את פעילות החברה, לגרום להפסדים כספיים ופגיעה במוניטין.

המלצה לטיפול: הגדרת מדיניות גיבוי מקיפה. ביצוע גיבויים סדירים לכל הנכסים הקריטיים. הטמעת גיבוי Off-site. ביצוע בדיקות שחזור תקופתיות.

תוכנית עבודה: קצר

נכס: מידע רגיש, מאגר סיסמאות, נתוני לקוחות

תיאור הסיכון: מידע רגיש המאוחסן במערכות החברה (במנוחה) אינו מוצפן, מה שחושף אותו לדליפה במקרה של פריצה פיזית או לוגית.

ממצא / חולשה: מאגר הסיסמאות מוצפן, אך שאר המידע הרגיש (לקוחות, קונפיגורציות) אינו מוצפן במנוחה.

ניתוח CIA: סודיות: גבוהה | שלמות: גבוהה | זמינות: בינונית

השפעה עסקית: דליפת מידע רגיש לא מוצפן עלולה לגרום לנזק תדמיתי, קנסות רגולטוריים ואובדן אמון לקוחות.

המלצה לטיפול: הטמעת הצפנה לכל המידע הרגיש במנוחה (Encryption at Rest). שימוש בכלי הצפנה מתאימים. ניהול מפתחות הצפנה מאובטח.

תוכנית עבודה: בינוני

נכס: תוכנות וקוד

תיאור הסיכון: אין בקרה על שימוש בתוכנות מורשות ובקניין רוחני. עובדים עשויים להשתמש בתוכנות פיראטיות או ללא רישיון.

ממצא / חולשה: אין מלאי רישיונות תוכנה. אין בקרה על התקנת תוכנות. שימוש בכלים חינוכיים ללא בדיקת רישוי.

ניתוח CIA: סודיות: נמוכה | שלמות: בינונית | זמינות: בינונית

השפעה עסקית: שימוש בתוכנות ללא רישיון חושף את החברה לתביעות משפטיות.

המלצה לטיפול: ניהול מלאי רישיונות. בקרה על התקנת תוכנות. הגדרת מדיניות שימוש בתוכנות.

תוכנית עבודה: טווח ארוך

הפניה לרגולציה: ISO 27001: A.18.1.2 – זכויות קניין רוחני.

נכס: מערכות חיצוניות, גישה מרחוק

תיאור הסיכון: אין בקרות מספקות על שימוש חיצוני במערכות הארגון (לדוגמה, גישת ספקים או לקוחות), מה שחושף את המערכות לסיכונים הנובעים מגישה בלתי מורשית.

ממצא / חולשה: אין מדיניות ברורה לגישה חיצונית. אין ניטור גישות חיצוניות. אין תהליך מסודר לביטול גישות חיצוניות.

ניתוח CIA: סודיות: בינונית | שלמות: בינונית | זמינות: בינונית

השפעה עסקית: גישה בלתי מורשית למערכות על ידי גורמים חיצוניים עלולה להוביל לדליפת מידע, פגיעה במערכות, ופגיעה במוניטין.

המלצה לטיפול: הגדרת מדיניות לגישה חיצונית. הטמעת בקרות גישה חזקות (כגון MFA). ביצוע ניטור וסקירות תקופתיות.

תוכנית עבודה: בינוני

5. הערכת סיכונים

5.1 טבלת מאסטר סיכונים - Top 10

#	תיאור הסיכון	הסתברות	השפעה	ציון סיכון
1	העדר הפרדת סביבות (רשתות לקוחות מול רשת פנימית)	גבוהה	גבוהה	קריטי
2	ניהול הרשאות מיוחדות (Least Privilege)	גבוהה	גבוהה	קריטי
3	העדר ניהול תיקוני אבטחה (Patch Management)	גבוהה	גבוהה	קריטי
4	חולשות באבטחת אתר המכירות	גבוהה	גבוהה	קריטי
5	העדר תוכנית המשכיות עסקית והתאוששות מאסון (BCP/DRP)	נמוכה	גבוהה	גבוהה
6	מדיניות אבטחת מידע כתובה ומאושרת	בינונית	גבוהה	גבוהה
7	הפרדת תפקידים	בינונית	גבוהה	גבוהה
8	Security by Design בפיתוח אתר המכירות	בינונית	גבוהה	גבוהה
9	מדיניות עבודה מרחוק	בינונית	גבוהה	גבוהה
10	תהליך בדיקת רקע לעובדים	בינונית	גבוהה	גבוהה

5.2 מפת חום סיכונים (Heatmap)

מפת חום זו מציגה את התפלגות 30 הסיכונים שזוהו לפי רמת ההסתברות וההשפעה שלהם.

השפעה / הסתברות	נמוכה	בינונית	גבוהה
גבוהה	סיכון 5, 25	סיכונים 6, 7, 8, 9, 10, 11, 12, 13, 15, 16, 17, 18, 19, 20, 21, 22, 23, 24, 26, 28	סיכונים 1, 2, 3, 4, 14, 27
בינונית		סיכון 29, 30	
נמוכה			

6. תוכנית עבודה לטיפול בסיכונים

תוכנית העבודה המוצעת מחולקת לשלושה שלבים, בהתאם לדחיפות והמורכבות של הטיפול בסיכונים:

6.1 שלב א' - מיידי (Quick Wins - עד 90 יום)

#	משימה	אחראי	שעות עבודה משוערות	תדירות
1	הטמעת תהליך Patch Management	צוות IT	50	חודשי
2	צמצום הרשאות Admin ויישום Least Privilege	צוות IT	80	חודשיים
3	הפעלת הצפנת TDE בבסיסי נתונים	צוות DBA	40	חודש
4	גיבוש מדיניות אבטחת מידע	CISO	60	3 חודשים
5	השקת תוכנית מודעות עובדים (פלטפורמה)	משאבי אנוש	30 + עלות	רבעוני
6	רישום מאגרי מידע	יועץ משפטי	20	חודשיים

6.2 שלב ב' - טווח בינוני (3-9 חודשים)

#	משימה	אחראי	שעות עבודה משוערות	תדירות
7	הפרדת סביבות פיתוח וייצור	צוותי פיתוח IT-1	200	6 חודשים
8	הטמעת תהליך ניהול פגיעויות (סורק)	צוות IT	120 + עלות	חצי שנתי
9	הגדרת תהליך ניהול גישה (JML)	צוות IT	100	חצי שנתי
10	הטמעת תהליך ניהול שינויים	צוות IT	80	רבעוני
11	גיבוש Incident Response Plan	CISO + IT	60	שנתי
12	הגדרת נוהל ניהול ספקים	מחלקה משפטית	80	שנתי

6.3 שלב ג' - טווח ארוך (9-18 חודשים)

#	משימה	אחראי	שעות עבודה משוערות	תדירות
13	הטמעת מערכת SIEM	צוות IT	300 + עלות	שנתי
14	גיבוי BCP/DRP מלא והקמת אתר DR	כלל ההנהלה	400 + עלות	שנתי
15	הטמעת מערכת DLP	צוות IT	150 + עלות	שנתי
16	הסמכה ל-ISO 27001	CISO	500 + עלות	חד פעמי

7. סיכום והמלצות

7.1 המלצות מרכזיות להנהלה

- **מחויבות הנהלה:** הנהלת סיסטרו טכנולוגיה נדרשת למחויבות מלאה לתהליך הטמעת ISO 27001 ולהקצאת המשאבים הנדרשים (תקציב, טכנולוגיה, כוח אדם).
- **מינוי CISO:** מינוי מנהל אבטחת מידע (CISO) בעל סמכויות מתאימות, שיוביל את תהליך הטמעת התקן וניהול אבטחת המידע השוטף.
- **תוכנית עבודה מדורגת:** יישום תוכנית העבודה המוצעת באופן מדורג, תוך התמקדות בסיכונים הקריטיים והגבוהים בטווח הקצר.
- **מודעות והדרכה:** השקעה בתוכניות מודעות והדרכה לעובדים, כיוון שהגורם האנושי הוא חוליה קריטית באבטחת המידע.
- **שיפור מתמיד:** הטמעת תהליכי בקרה וסריקה תקופתיים להבטחת שיפור מתמיד של מערך אבטחת המידע.

ROI 7.2 - החזר השקעה וערך עסקי

ההשקעה באבטחת מידע ובתהליך ההסמכה ל-ISO 27001 צפויה להניב החזר השקעה משמעותי וערך עסקי רב לסיסטרו טכנולוגיה:

- **מניעת קנסות רגולטוריים:** עמידה בתקן מפחיתה את הסיכון לקנסות משמעותיים (עד 4% מהמחזור השנתי) עקב הפרות אבטחת מידע.
- **הגנה על המוניטין:** שמירה על תדמית חיובית ואמון לקוחות, שהם נכסים קריטיים לחברה.
- **יתרון תחרותי:** הסמכה ל-ISO 27001 מהווה יתרון משמעותי במכרזים ומול לקוחות הדורשים עמידה בתקנים בינלאומיים.
- **הפחתת עלויות אירועי סייבר:** צמצום הנזק הכספי והתפעולי הנובע מאירועי אבטחה ופריצות.

8. נספחים

8.1 נספח א' - טבלת מאסטר סיכונים מלאה (30 סיכונים)

(ראה סעיף 4.2 ו-5.1 לפירוט המלא של 30 הסיכונים).

8.2 נספח ב' - מילון מונחים

מונח	הסבר
ISO 27001	תקן בינלאומי לניהול אבטחת מידע.
CIA	סודיות (Confidentiality), שלמות (Integrity), זמינות (Availability).
CISO	מנהל אבטחת מידע (Chief Information Security Officer).
WAF	Web Application Firewall - פיירוול ליישומי אינטרנט.
MFA	Multi-Factor Authentication - אימות רב-שלבי.
SIEM	Security Information and Event Management - ניהול אירועי אבטחה ומידע.
BCP	Business Continuity Plan - תוכנית המשכיות עסקית.
DRP	Disaster Recovery Plan - תוכנית התאוששות מאסון.

8.3 נספח ג' - רשימת מרואיינים

- מנהל IT.

- צוות פיתוח אתר המכירות.

- טכנאי שטח בכירים.

- מנהלת משרד.



סיסטרו טכנולוגיה — SYSTRU Technology

מסמך סודי — לשימוש פנימי בלבד

14 באפריל 2026